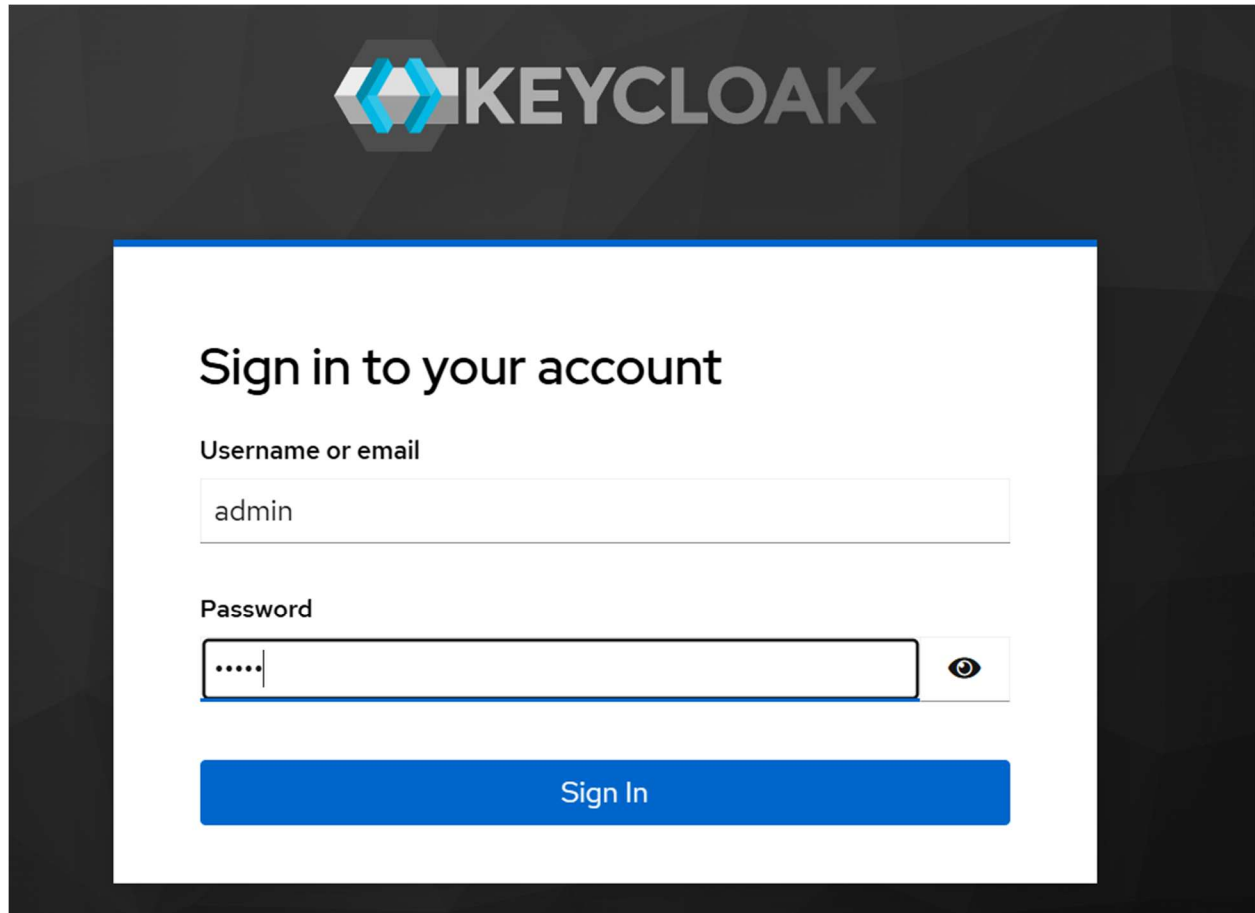


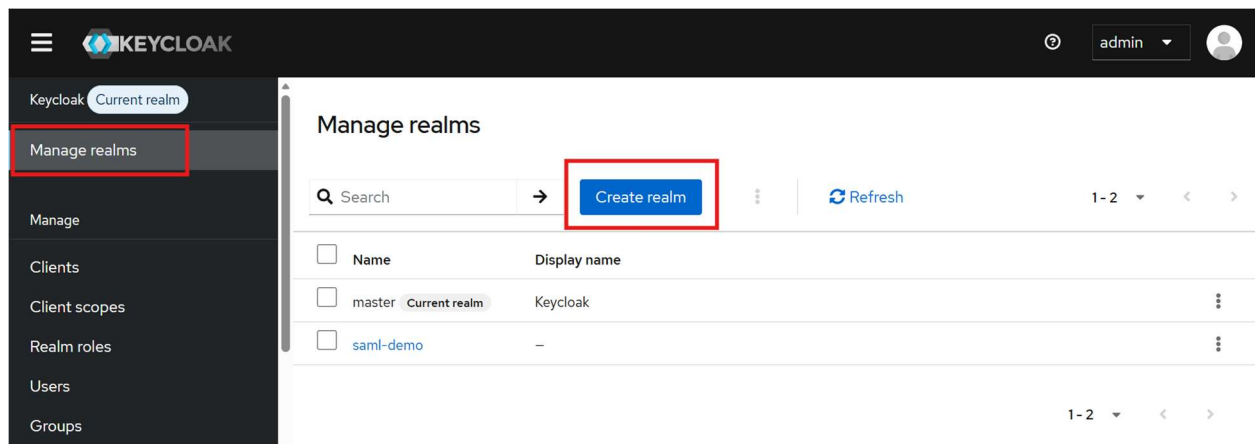
How to Configure Keycloak to Setup SAML Single Sign On

Suppose Keycloak server starts at localhost:9991. Login as Admin/Admin

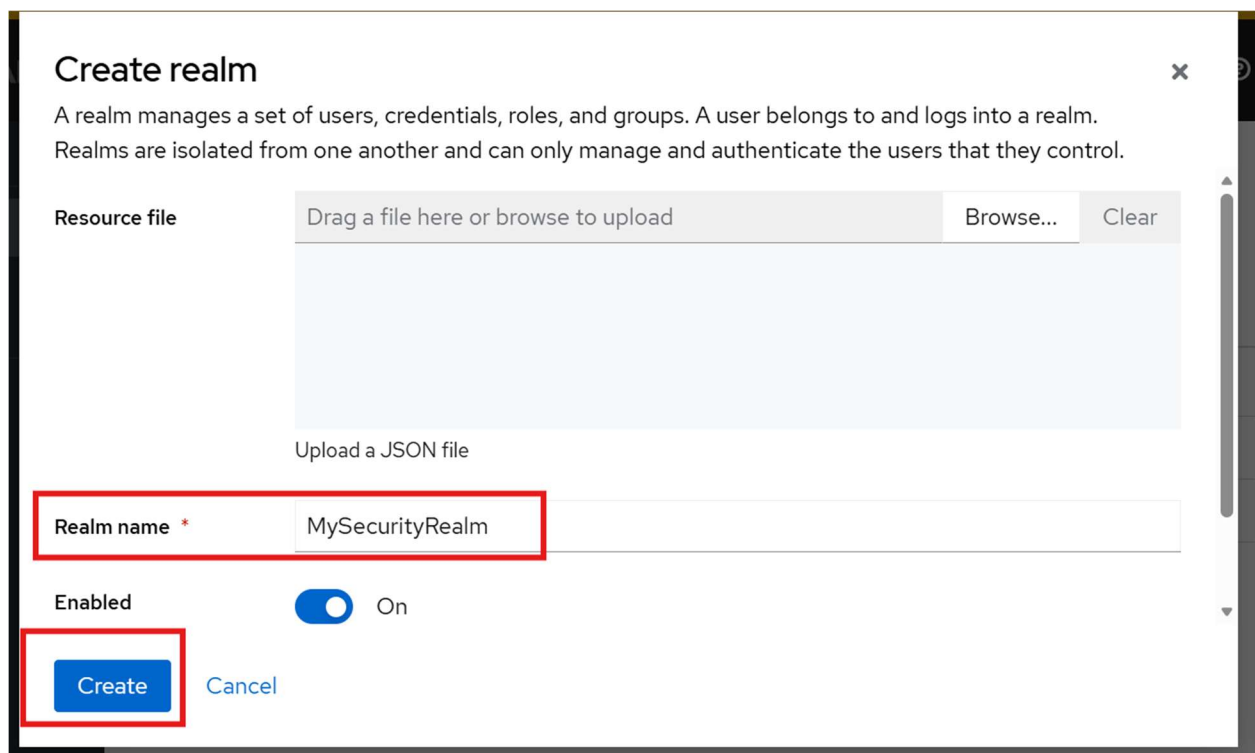
The image shows the Keycloak login page. At the top, there is a Keycloak logo consisting of a blue and grey hexagonal icon followed by the word 'KEYCLOAK' in a bold, sans-serif font. Below the logo, the heading 'Sign in to your account' is displayed in a large, black, sans-serif font. Underneath the heading, there are two input fields. The first is labeled 'Username or email' and contains the text 'admin'. The second is labeled 'Password' and contains five dots, indicating a masked password. To the right of the password field is an eye icon for toggling password visibility. At the bottom of the form is a blue button with the text 'Sign In' in white.

Create a Security Realm

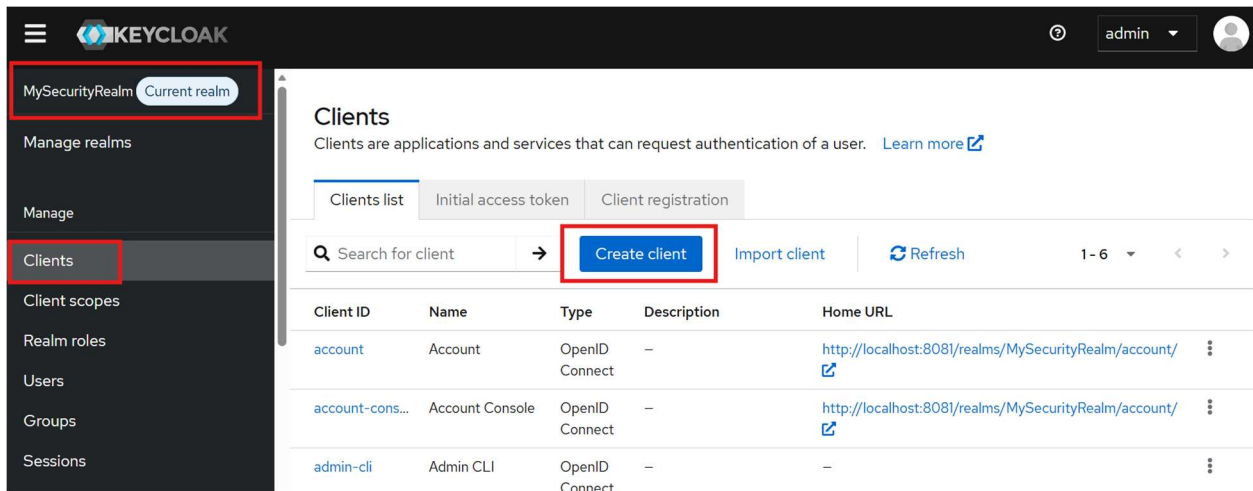
Click Mange realms and then Create realm:



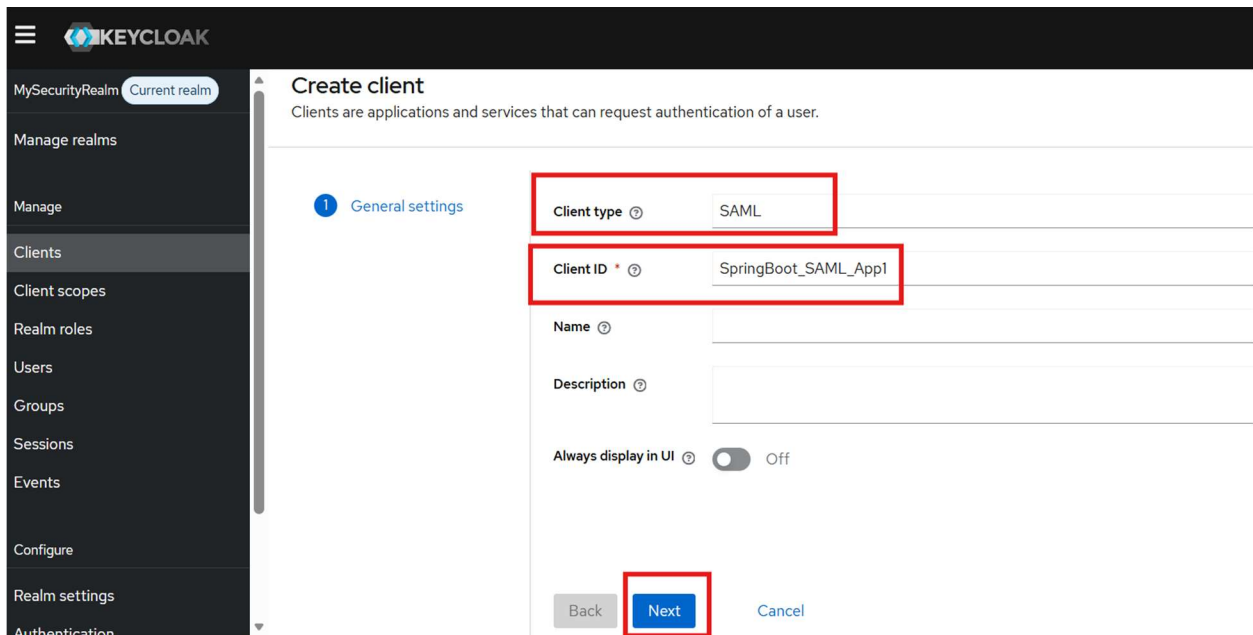
Provide a realm name then click Create:



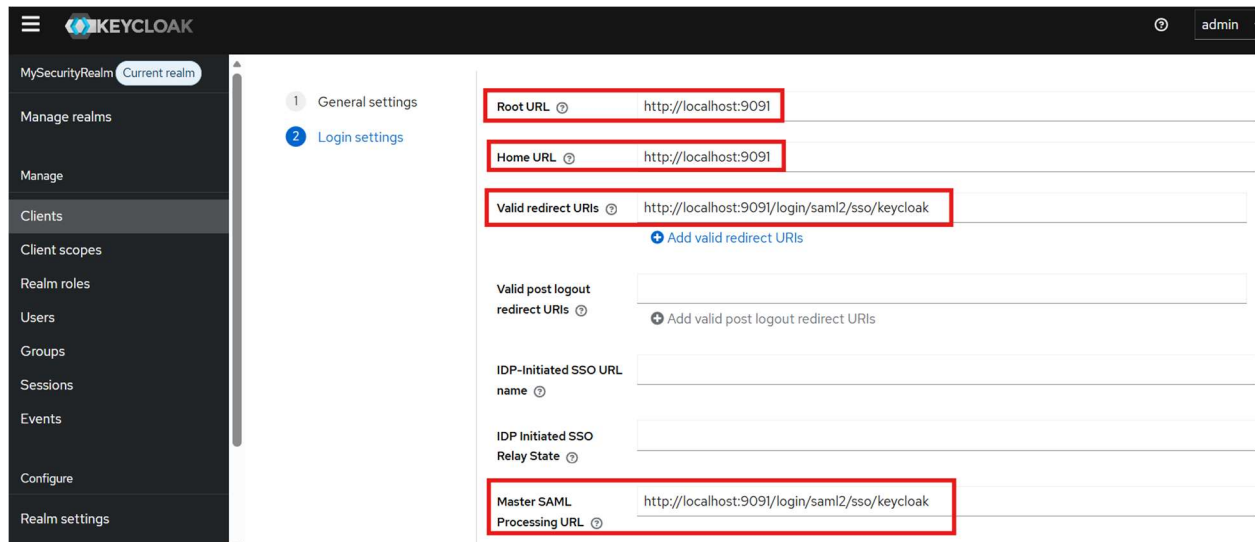
Explore realm SAML metadata by clicking Realm settings, then click SAML 2.0 Identity Provider Metadata. Such metadata contains important information for applications (SP) to communicate with Keycloak during authentication. It should be include in the security configuration of the Spring applications.



Choose Client type: SAML, enter Client ID: SpringBoot_SAML_App1, then click Next:



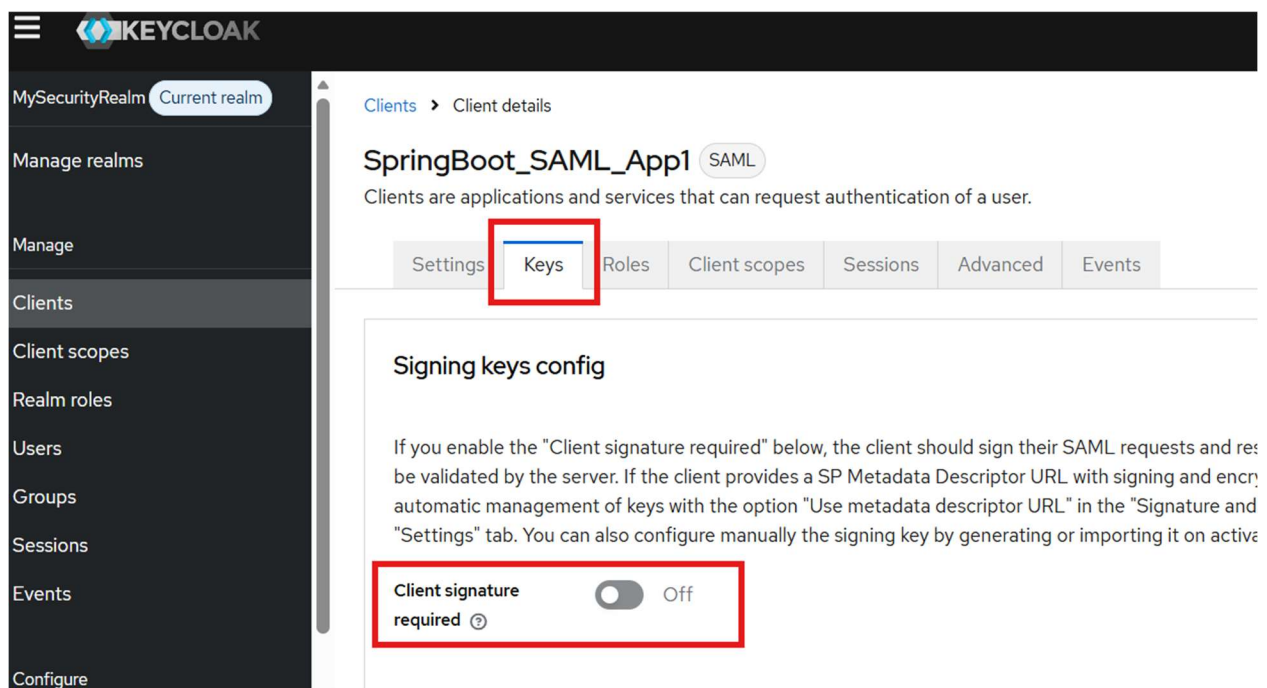
Enter the URLs about the Spring Boot application and click Save. The Master SAML Processing URL will be used for every binding to both the SP's Assertion Consumer and Single Logout Services. “/login/saml2/sso/keycloak” is a default URL that tells Spring Security to handle SAML Assertion Consumption.



The image shows the Keycloak Admin Console interface for the 'MySecurityRealm' (Current realm). The left sidebar contains navigation links: Manage realms, Manage, Clients, Client scopes, Realm roles, Users, Groups, Sessions, Events, Configure, and Realm settings. The main content area is titled 'Login settings' and includes the following fields:

- Root URL: [http://localhost:9091](#)
- Home URL: [http://localhost:9091](#)
- Valid redirect URIs: [http://localhost:9091/login/saml2/sso/keycloak](#) (with a link to 'Add valid redirect URIs')
- Valid post logout redirect URIs: (with a link to 'Add valid post logout redirect URIs')
- IDP-Initiated SSO URL name:
- IDP Initiated SSO Relay State:
- Master SAML Processing URL: [http://localhost:9091/login/saml2/sso/keycloak](#)

Temporally disable Client signature required. Signature is about public key/private key (TODO)



The image shows the Keycloak Admin Console interface for the 'MySecurityRealm' (Current realm). The left sidebar contains navigation links: Manage realms, Manage, Clients, Client scopes, Realm roles, Users, Groups, Sessions, Events, Configure, and Realm settings. The main content area is titled 'Client details' for 'SpringBoot_SAML_App1' (SAML). The 'Keys' tab is selected, showing the 'Signing keys config' section. The 'Client signature required' toggle is set to 'Off'.

SpringBoot_SAML_App1 (SAML)

Clients are applications and services that can request authentication of a user.

Settings Keys Roles Client scopes Sessions Advanced Events

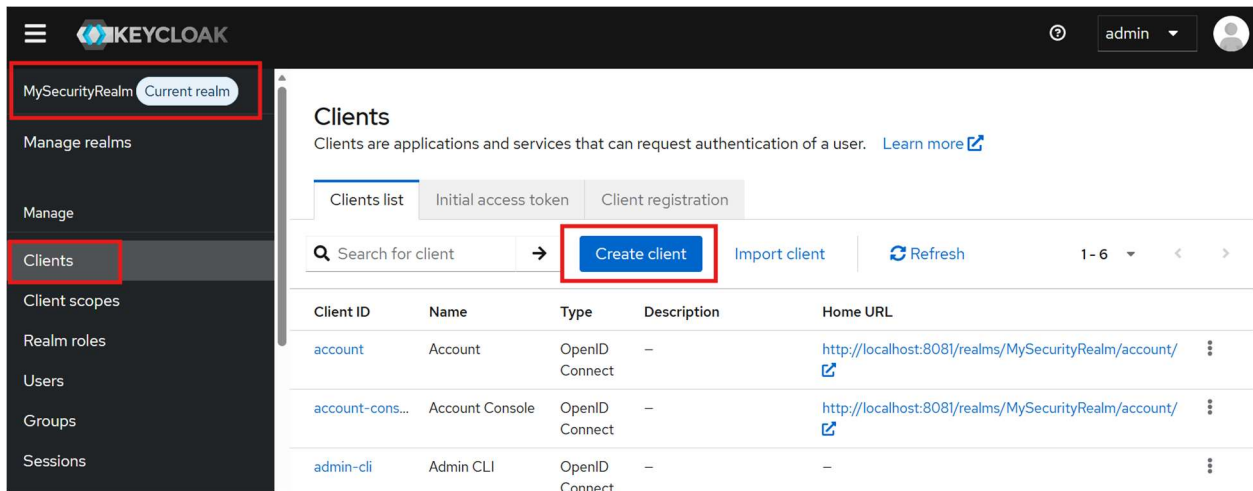
Signing keys config

If you enable the "Client signature required" below, the client should sign their SAML requests and be validated by the server. If the client provides a SP Metadata Descriptor URL with signing and encryption, automatic management of keys with the option "Use metadata descriptor URL" in the "Signature and Settings" tab. You can also configure manually the signing key by generating or importing it on active.

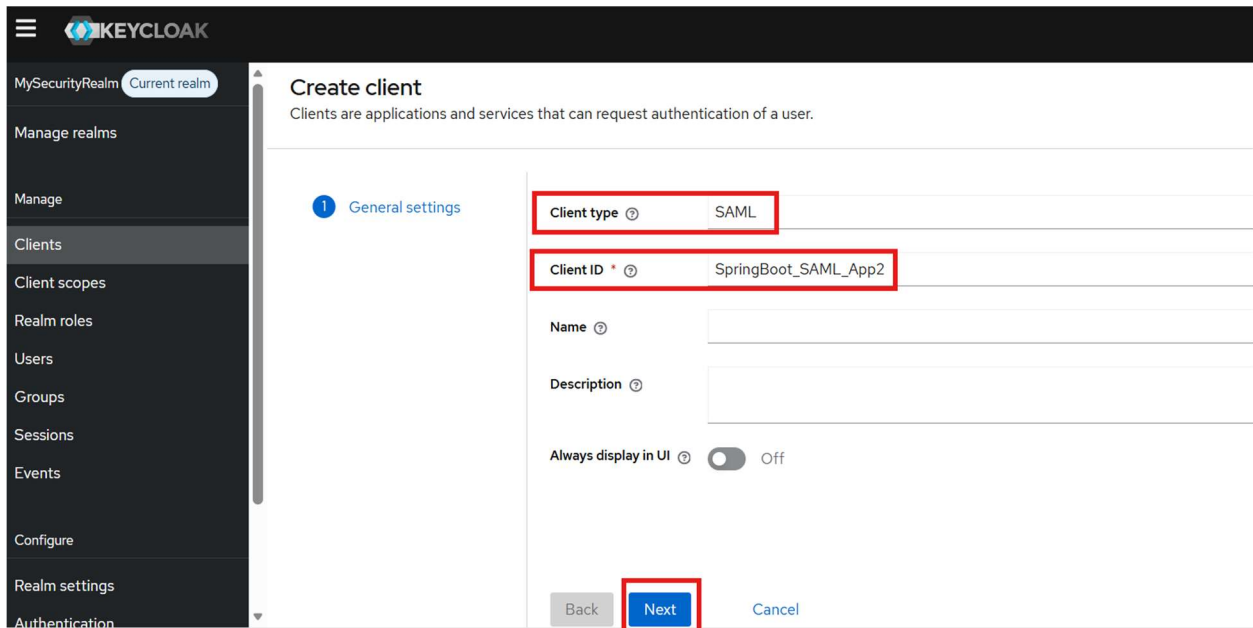
Client signature required ☐ Off

Create a 2nd Client:

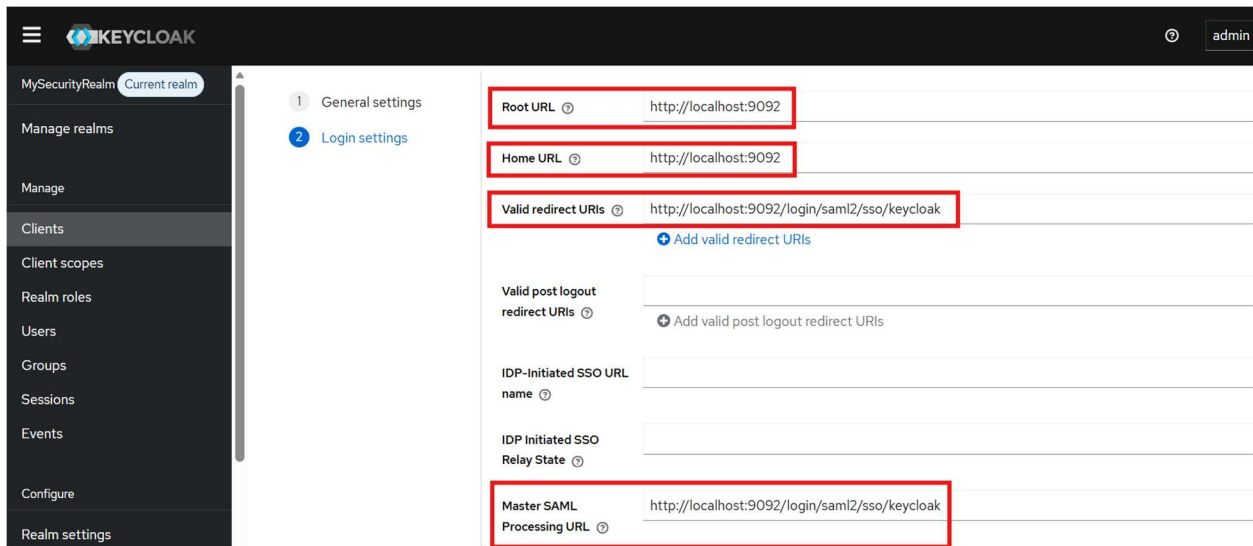
Click Clients then click Create client:



Choose Client type: SAML, enter Client ID: SpringBoot_SAML_App2, then click Next:



Enter the URLs about the Spring Boot application and click Save. The Master SAML Processing URL will be used for every binding to both the SP's Assertion Consumer and Single Logout Services. “/login/saml2/sso/keycloak” is a default URL that tells Spring Security to handle SAML Assertion Consumption.

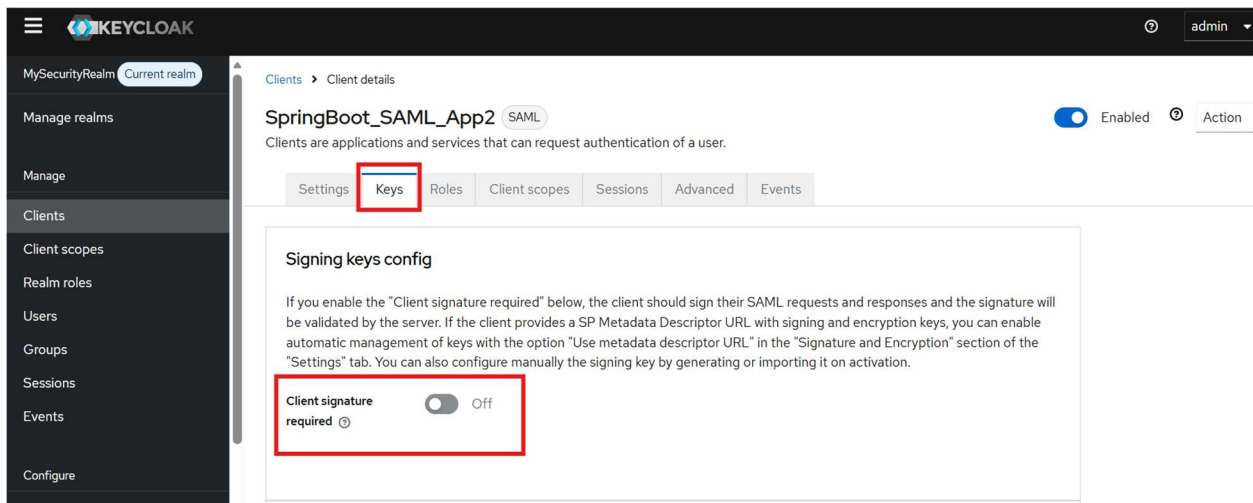


The image shows the 'Login settings' tab in the Keycloak Admin Console for the 'MySecurityRealm' (Current realm). The left sidebar contains navigation links: Manage realms, Manage, Clients, Client scopes, Realm roles, Users, Groups, Sessions, Events, Configure, and Realm settings. The main content area shows the 'Login settings' configuration. The following fields are highlighted with red boxes:

- Root URL**: http://localhost:9092
- Home URL**: http://localhost:9092
- Valid redirect URIs**: http://localhost:9092/login/saml2/sso/keycloak
- Master SAML Processing URL**: http://localhost:9092/login/saml2/sso/keycloak

Other visible fields include 'Valid post logout redirect URIs' (with an 'Add valid post logout redirect URIs' button), 'IDP-Initiated SSO URL name', and 'IDP Initiated SSO Relay State'.

Temporally disable Client signature required. Signature is about public key/private key (TODO)



The image shows the 'Client details' page for 'SpringBoot_SAML_App2' (SAML) in the Keycloak Admin Console. The left sidebar is the same as the previous image. The main content area shows the 'Keys' tab selected. The 'Client details' header shows 'SpringBoot_SAML_App2' (SAML) with a toggle for 'Enabled' (checked) and an 'Action' button. Below the tabs (Settings, Keys, Roles, Client scopes, Sessions, Advanced, Events), the 'Signing keys config' section is visible. It contains the following text:

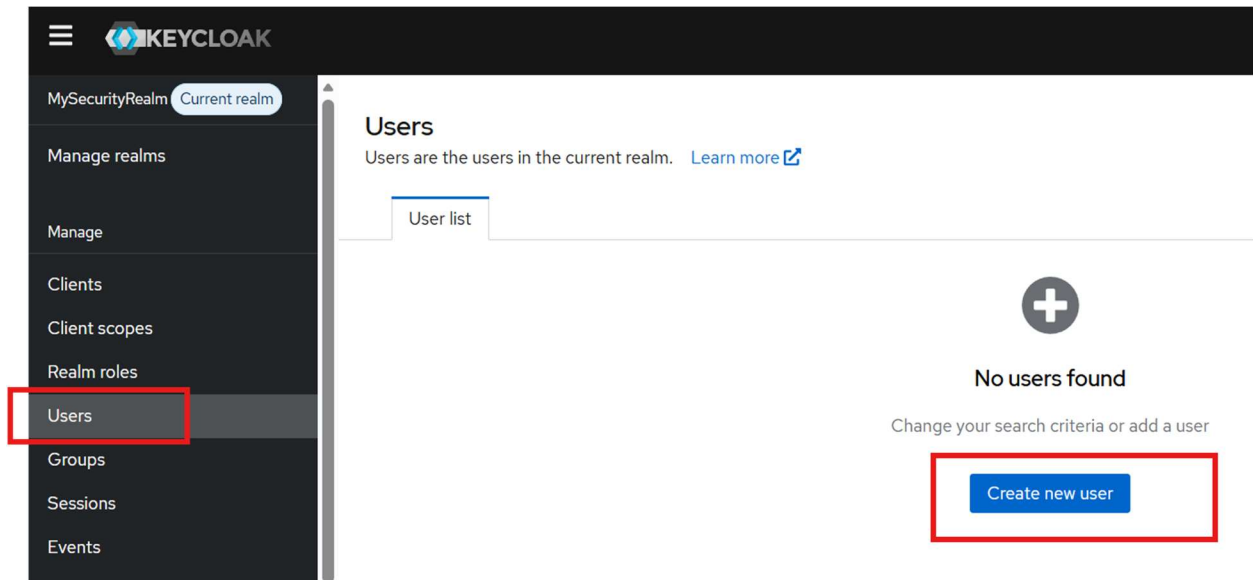
If you enable the "Client signature required" below, the client should sign their SAML requests and responses and the signature will be validated by the server. If the client provides a SP Metadata Descriptor URL with signing and encryption keys, you can enable automatic management of keys with the option "Use metadata descriptor URL" in the "Signature and Encryption" section of the "Settings" tab. You can also configure manually the signing key by generating or importing it on activation.

The 'Client signature required' toggle is currently set to 'Off' and is highlighted with a red box.

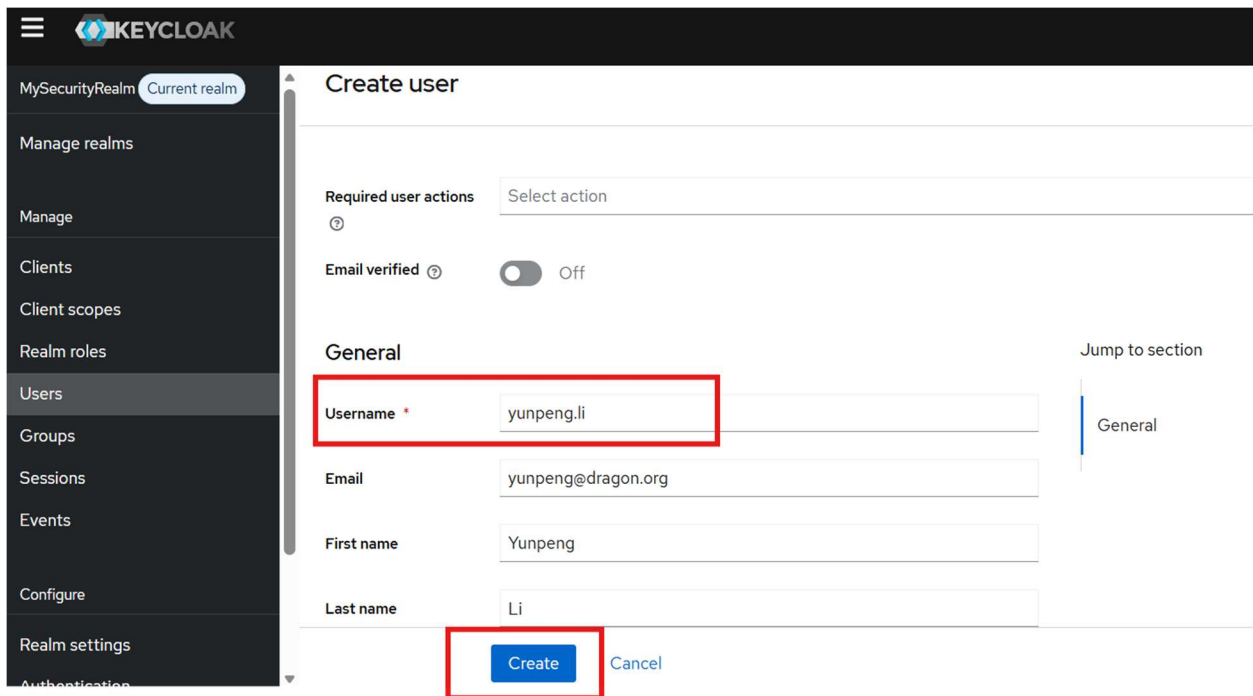
Create User in the Security Realm

A user in a Security Realm can potentially single sign on all Service Providers (Spring applications) configured under the Security Realm.

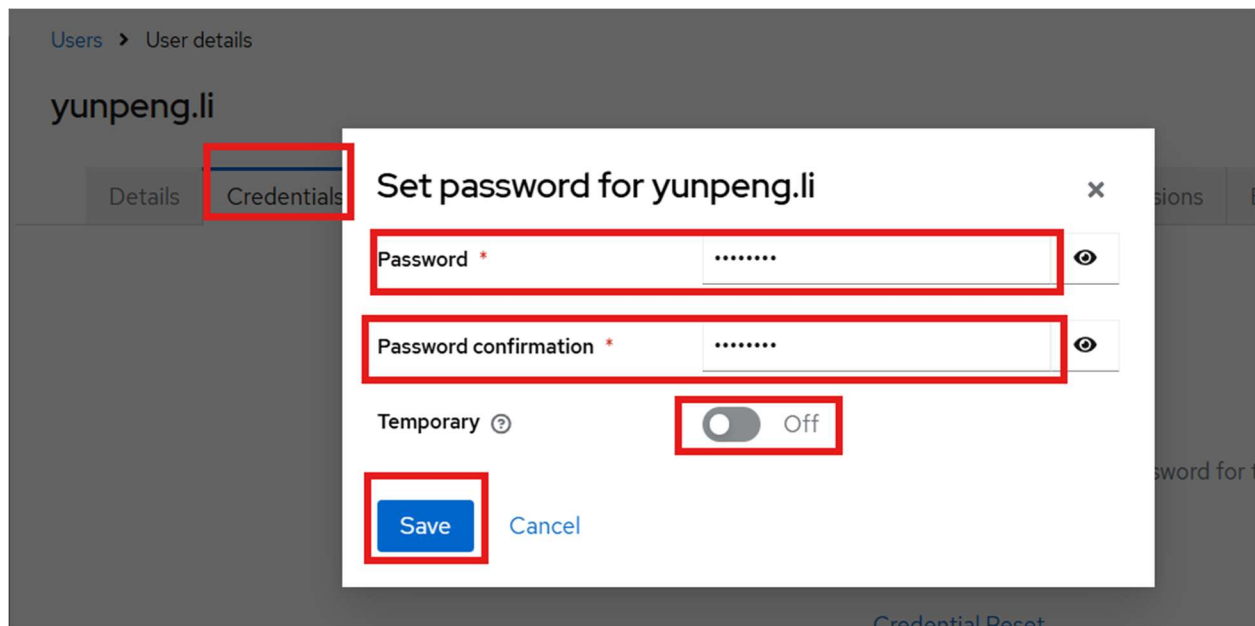
Click Users link and then click Create new user:



Enter Username and other information then click Create:

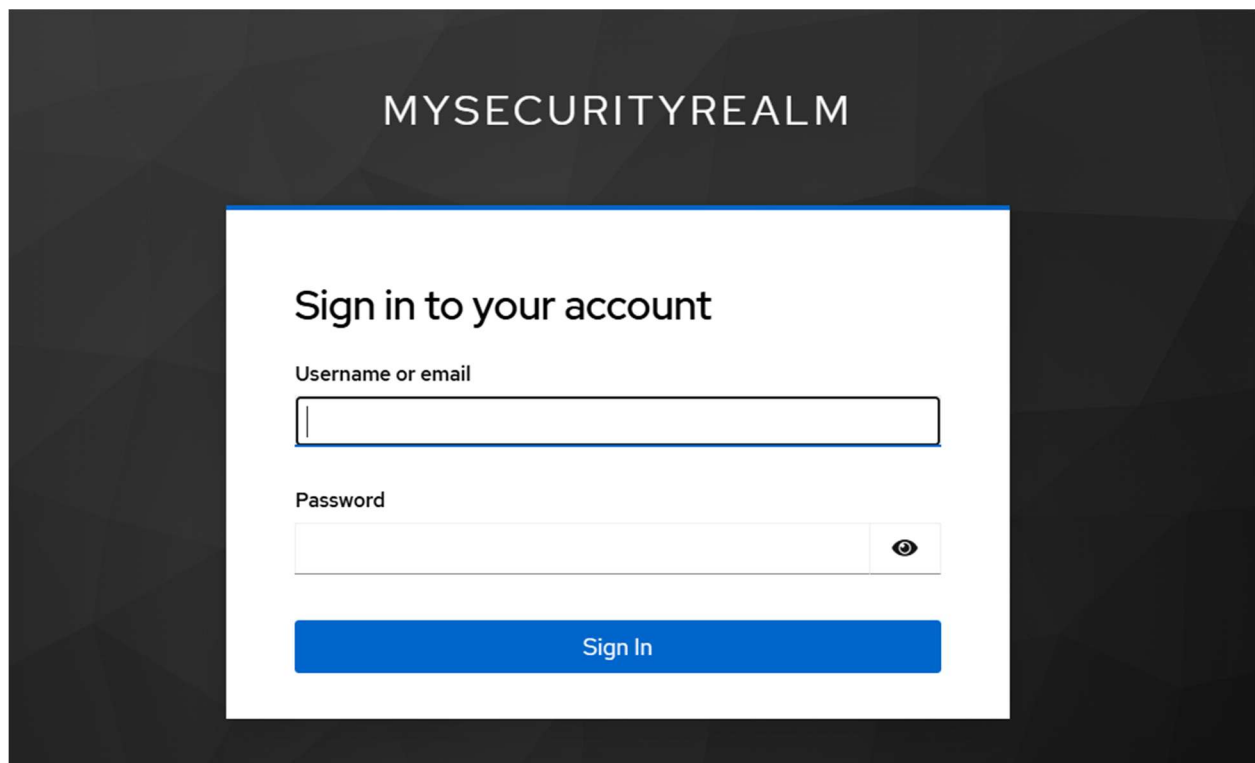


Click the Credential tab, then in the popup form, enter the password and choose the Temporary selection as Off (It won't ask user to change password when first login), then click Save:

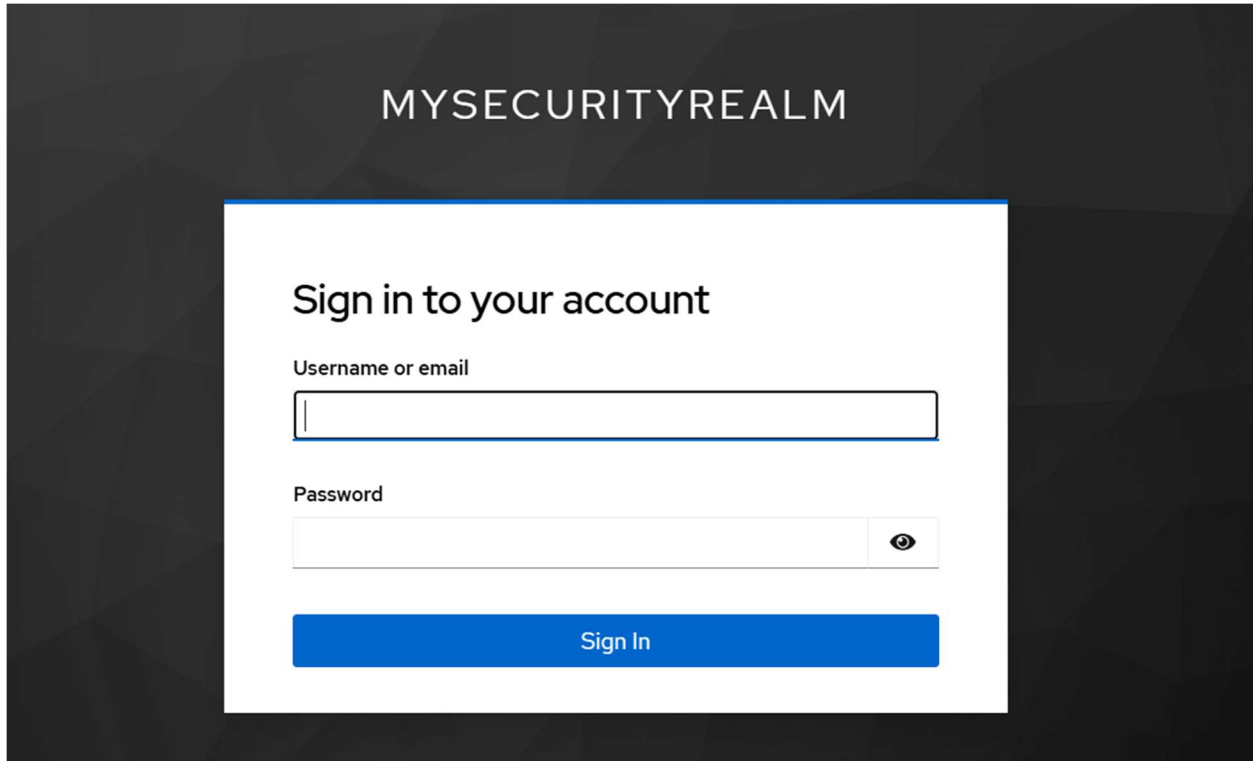


Demonstrate Single Sign On for two Spring Boot Applications

Start SpringBoot_SAML_App1, then access <http://localhost:9091> in a browser. It will redirect to a Keycloak login screen:



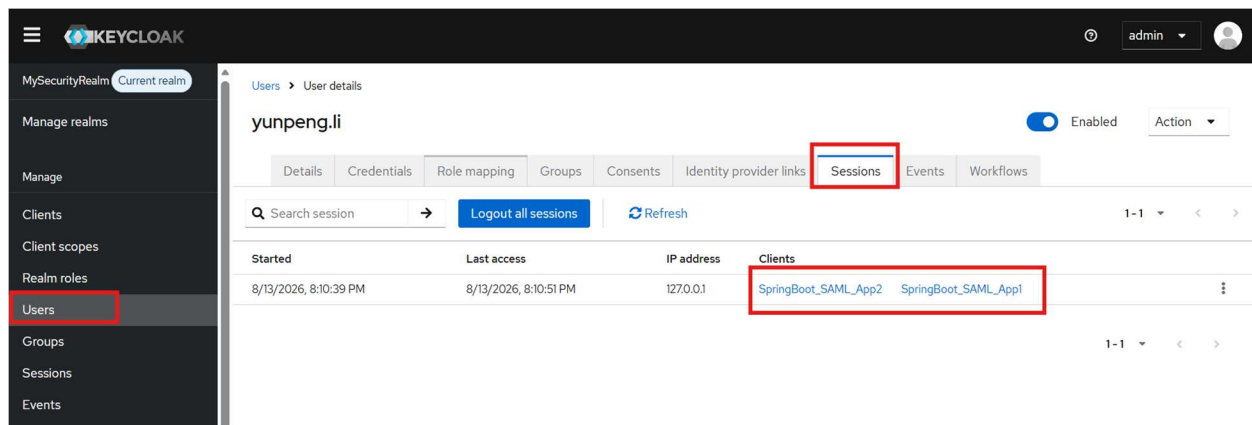
Start SpringBoot_SAML_App2, then access <http://localhost:9092> in a browser. It will redirect to a Keycloak login screen:



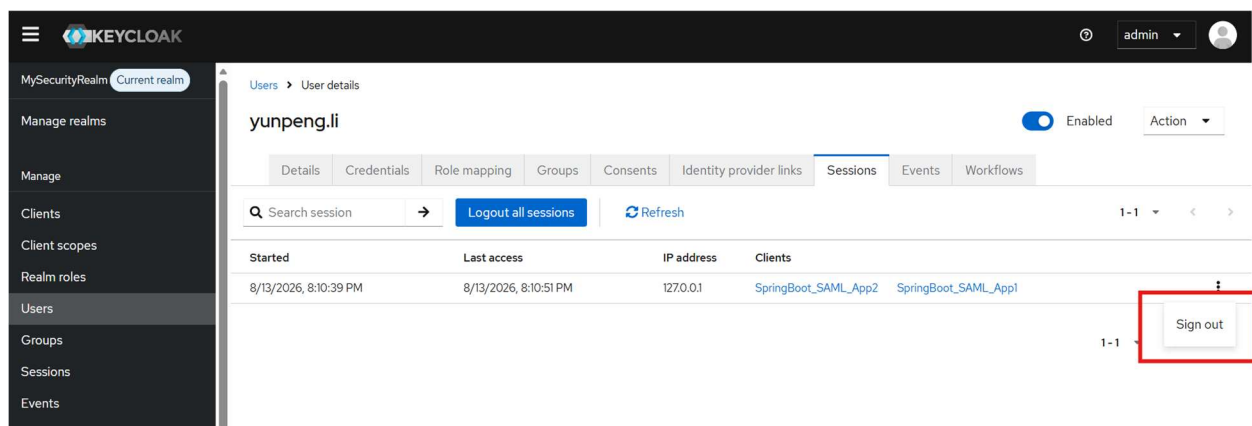
In the login screen for SpringBoot_SAML_App1, enter username (yunpeng.li) and password (password) and click Sign In. It will redirect to the home page of SpringBoot_SAML_App1.

Retype the URL <http://localhost:9092> for SpringBoot_SAML_App2 in the browser. It will not show Keycloak login page but show the home page of SpringBoot_SAML_App2.

Login as admin in Keycloak and access Users under the Security Realm. It shows the user has both client sessions:



You can sign out the user from both client sessions:



After user is signed out, accessing SpringBoot_SAML_App1 or SpringBoot_SAML_App2 requires login again.

Important URLs:

URL	Owned by	Purpose
http://localhost:9091/saml2/authenticate/keycloak http://localhost:9092/saml2/authenticate/keycloak	Spring	Start SAML login
http://localhost:9991/realms/MySecurityRealm/protocol/saml	Keycloak	Receive AuthnRequest / perform SSO
http://localhost:9091/login/saml2/sso/keycloak http://localhost:9092/login/saml2/sso/keycloak	Spring	ACS: receive SAMLResponse
http://localhost:9091/saml2/metadata/keycloak http://localhost:9092/saml2/metadata/keycloak	Spring	Spring SP metadata
http://localhost:9991/realms/MySecurityRealm/protocol/saml/descriptor	Keycloak	Keycloak IdP metadata